Industrial Security (Bachelor)

Exercise Sheet – Section 02

ICS and SCADA Fundamentals

Goal of this sheet

Reason about the building blocks of an industrial control system the way an engineer on shift does: from a single scan cycle on a PLC, through ladder logic on the rung, up to the HMI, historian, engineering workstation, and the safety layer that sits beside all of them. Each task is a short plant-floor scenario; aim for technical, specific answers rather than slide-level definitions.

Exercise 2.1 – Worst-Case Scan-Cycle Latency

A Siemens S7-1500 controls a bottling line. Its program runs with a measured cycle time of 12 ms. A digital input wired to a photoelectric sensor must trigger an air-blast reject within 40 ms of a bad bottle passing the sensor. The output card has a quoted hardware response of 2 ms; the input filter is configured to 3 ms.

1. Compute the worst-case end-to-end latency from a bottle breaking the beam to the air valve actually opening. Show your work; assume the bottle arrives just *after* the input-read phase of the current cycle.
2. Does the system meet the 40 ms budget? By how much?
3. Name one change (other than "buy a faster PLC") that would shave the worst-case latency, and one that would make it predictably worse.

Exercise 2.2 – Read This Ladder Rung

Consider the following ladder rung on an Allen-Bradley CompactLogix L24ER. `X1` is a NO contact from the Start pushbutton, `X2` is a NC contact from the Stop pushbutton, `X3` is a NO contact from a level switch (asserted when the tank is *not* full), and `Y1` drives the fill-pump contactor. `Y1` also feeds back as a NO seal-in contact around `X1`.

```
|   X1      X2(NC)    X3        Y1   |
|--] [---+--]/[------] [-------(   )-|
|        |                           |
|   Y1   |                           |
|--] [---+                           |
```

1. Walk through what happens when the operator briefly presses Start (`X1` goes high for 200 ms) while the tank is half full.
2. What happens at the moment `X3` drops out (tank reaches the high-level switch)?
3. What happens if the wire to the Stop pushbutton is cut? Is that the desired behaviour? Explain in one sentence.

Exercise 2.3 – Why Is SIS Isolated from the BPCS?

A greenfield ethylene cracker is being designed. A junior engineer proposes saving cost by running the safety interlocks as additional logic on the same Schneider M580 that already runs the Basic Process Control System (BPCS), arguing that the M580 supports redundancy.

1. Give two *technical* reasons why the safety logic must run on a separate, SIL-rated controller (e.g. Schneider Triconex or Siemens HIMA) rather than sharing the BPCS controller.
2. Give one *regulatory or standards-based* reason. Name the standard.
3. Sketch in two or three sentences how a TRITON-style attack would be made harder by the separation you just justified.

Exercise 2.4 – You Inherit a Windows XP HMI

You take over the OT team at a mid-sized brewery. The pasteurisation line runs a Wonderware InTouch (now AVEVA InTouch) HMI from 2008 on Windows XP Embedded. Replacement is firmly off the table for at least the next 12 months: the HMI graphics are tied to a custom recipe-management add-on whose vendor is bankrupt.

1. List the five most realistic mitigations you would apply within the next quarter. For each one, give a single concrete action (vendor, product, or configuration), not just a principle.
2. Identify which mitigation gives you the most risk reduction per euro, and justify in one sentence.
3. Name one mitigation that sounds attractive but you would *reject*, and say why.

Exercise 2.5 – OPC UA on Pump P-101

Pump P-101 has a Balluff BCM vibration sensor that exposes its readings as an OPC UA server on the plant network. A maintenance engineer wants to read the velocity-RMS variable from her laptop using UAExpert.

1. List what the engineer's laptop minimally needs in order to read the variable: network reachability, client software, and any OPC UA-specific items (think security policy, user token, certificates).
2. An attacker on the same VLAN wants to read the same variable. What do they need that the engineer also needs, and what (if anything) do they additionally need, given a typical out-of-the-box deployment?
3. Name one configuration change that would still let the engineer work but materially raise the bar for the attacker.

Exercise 2.6 – Historian Used for Billing

The historian at a district heating plant runs AVEVA PI System. Hourly energy-delivered totals are read from PI by the billing system and become the legal basis for customer invoices.

1. List three integrity controls you would deploy on this historian that you would *not* bother deploying on an identical historian used only for engineering research.
2. For each control, name where it lives (PI Server, PI Asset Framework, the OS, the network, the billing system) and one specific feature or product that implements it.
3. Briefly: which control would you also add if the regulator could issue an unannounced audit (one sentence)?

Exercise 2.7 – Open-Book: S7-1500 Scan-Time Limits

Open-book exercise. Using the official Siemens S7-1500 system manual (document ID `6ES7 System Manual`, current edition on `support.industry.siemens.com`):

1. State the minimum cycle time the user can configure for a cyclic OB on an S7-1500 CPU, and the default maximum cycle-time monitoring value.
2. Cite the section or table number you used.
3. Explain in one or two sentences *why* Siemens exposes both a minimum and a maximum, rather than just letting the CPU run as fast as it can.

Hint

The relevant chapter is "Cycle and reaction times". Different CPU SKUs (1511, 1513, 1515, 1517, 1518) have slightly different numbers; pick one and name it.

Exercise 2.8 – Spot the Bug: Misplaced Seal-In

A maintenance technician hands you the following rung from a Rockwell Studio 5000 project for a conveyor motor. `Start` and `Stop` are pushbuttons; `Run` is the motor-contactor output. The intent is a standard latched start/stop.

```
|   Start    Stop(NC)              Run  |
|--] [------]/[------+-------------(   )-|
|                    |                  |
|   Start            |                  |
|--] [---------------+                  |
```

1. What is wrong with this rung compared to a correct start/stop latch?
2. Describe exactly what the operator sees when she presses and releases Start, and then presses Stop.
3. Redraw the corrected rung (text-art is fine), explicitly naming the contact that should be used for the seal-in.

Exercise 2.9 – Component Mapping (One per Major Role)

For each of the six descriptions below, name the single most appropriate component from the set {**PLC**, **RTU**, **HMI**, **Historian**, **Engineering WS**, **SIS**} and, in one sentence, justify why the others would be wrong.

1. Runs a 5 ms scan cycle of ladder logic on the factory floor and drives the I/O cards directly.
2. Trips an emergency shut-down valve within 100 ms when reactor pressure exceeds 18 bar, independent of the BPCS.
3. Holds the only authoritative copy of the project file and the credentials to download new firmware to thirty CompactLogix CPUs.
4. Polls a remote substation over a private DNP3 link with poor radio coverage and buffers events when the link is down.
5. Compresses ten years of 1 s-resolution tag values and serves them to a Power BI dashboard via OLEDB.

6. Displays a P&ID-style mimic of the boiler house with live values and an alarm summary bar to the night-shift operator.

Exercise 2.10 – Lab: OpenPLC + Modbus TCP

Complete `labs/lab-01-openplc` on your own machine.

1. Install OpenPLC Runtime and OpenPLC Editor.
2. Implement the corrected start/stop latch from Exercise 2.8 in Ladder Diagram.
3. Drive it from a soft HMI of your choice (ScadaBR, Node-RED dashboard, or Ignition Maker Edition).
4. Capture the Modbus TCP traffic with Wireshark while you press Start and Stop. Identify the function codes the HMI uses.
5. Briefly note: is there anything in the captured frames that would stop an attacker on the same network from issuing the same writes?

Hint

Section 04 dissects Modbus in detail; bring the pcap from this lab.